

Student Name: Enow Joshua
University :
Major : Cyber Security
Internship Duration : April 10th, 2025-May 3rd, 2025
Company: Hack Security
Mentor: Mr Nishant Prajapati
Assistant Mentor: Mr Aman Pandey
Cordinator: Mr Shivam Kapoor

Objectives

My primary objective of this internship were to:

- 1) Develop a deep understanding of cybersecurity principles and practices.
- 2) Gain hands-on experience in identifying, analyzing and mitigating security threats.
- 3) Enhance my skills in using cybersecurity tools and techniques in real-world scenarios.

Task and Responsibilities

During my internship, I was involved in the following key tasks:

- **Vulnerability Assessment:** Conducted a thorough scan of a target website to identify open ports and potential vulnerabilities.
- **Penetration Testing:** Performed brute-force attacks and directory enumeration on the website to uncover hidden directories and files.
 - **Traffic Analysis:** Intercepted network traffic using Wireshark during a simulated login attempt, successfully capturing and analyzing transmitted credentials.
- **Decryption and Cryptanalysis:** Decrypted password-protected files using cryptographic tools and analyzed encoded hash values to recover plaintext passwords.
- **Reverse Engineering:** Used PE Explorer to analyze an executable file, identifying the entry point and other critical information.
- **Network Security:** Executed a de-authentication attack on a controlled network environment, capturing the handshake and subsequently cracking the Wi-Fi password using a custom wordlist.
- **Payload Creation:** Developed and deployed a Metasploit payload to establish a reverse shell connection on a virtual machine.

Internship Task

1. Find all the ports that are open on the website <http://testphp.vulnweb.com/>

On the website, I discovered port 80 (tcp) is the open port. Bellow is a clear diagram of the command used in scanning for open port and the result that was gotten from the scan. Namp -p - <http://testphp.vulnweb.com/>. This is used to carryout a full scan.

```

root@dante-Latitude-E7450: /home/dante
root@dante-Latitude-E7450: /home/dante
root@dante-Latitude-E7450: /home/dante

sendto in send_ip_packet_sd: sendto(5, packet, 44, 0, 44.228.249.3, 16) => Network is unreachable
Offending packet: TCP 192.168.1.193:50262 > 44.228.249.3:1027 S ttl=49 (id=27559 lplen=44 seq=3338413231 win=1024 <ms 1460>
sendto in send_ip_packet_sd: sendto(5, packet, 44, 0, 44.228.249.3, 16) => Network is unreachable
Offending packet: TCP 192.168.1.193:50261 > 44.228.249.3:1046 S ttl=52 (id=11314 lplen=44 seq=3338478760 win=1024 <ms 1460>
sendto in send_ip_packet_sd: sendto(5, packet, 44, 0, 44.228.249.3, 16) => Network is unreachable
Offending packet: TCP 192.168.1.193:50262 > 44.228.249.3:1046 S ttl=48 (id=43764 lplen=44 seq=3338413231 win=1024 <ms 1460>
sendto in send_ip_packet_sd: sendto(5, packet, 44, 0, 44.228.249.3, 16) => Network is unreachable
Offending packet: TCP 192.168.1.193:50261 > 44.228.249.3:1060 S ttl=56 (id=36830 lplen=44 seq=3338413231 win=1024 <ms 1460>
sendto in send_ip_packet_sd: sendto(5, packet, 44, 0, 44.228.249.3, 16) => Network is unreachable
Offending packet: TCP 192.168.1.193:50262 > 44.228.249.3:1060 S ttl=56 (id=36830 lplen=44 seq=3338413231 win=1024 <ms 1460>
sendto in send_ip_packet_sd: sendto(5, packet, 44, 0, 44.228.249.3, 16) => Network is unreachable
Offending packet: TCP 192.168.1.193:50261 > 44.228.249.3:10629 S ttl=41 (id=27785 lplen=44 seq=3338478760 win=1024 <ms 1460>
Stats: 0:01:58 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan timing: About 40.76% done; ETC: 18:49 (6:02:52 remaining)
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.31s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered ports
PORT      STATE SERVICE VERSION
80/tcp open  http    nginx 1.19.0
|_http-title: Home of Acunetix Art
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: CentOS IPANEL control system (90%), Openmint Kanikaze 7.00 (Linux 2.6.22) (60%), Openmint 0.9 - 7.00 (Linux 2.4.30 - 2.4.34) (88%), Openmint White Russian 0.9 (Linux 2.4.30) (88%), A
SUS RI-NSOU MAP (Linux 3.4) (87%), Linux 3.1 (87%), Linux 3.10 (87%), Linux 3.2 (87%), HP P2000 G3 NAS device (87%), AXIS 210A or 211 Network Camera (Linux 2.6.17) (87%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 24 hops

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 4.47 ms _gateway (192.168.1.1)
2 ...
3 29.33 ms 10.0.23.97
4 ... 6
7 32.67 ms 10.0.23.92
8 ... 0
10 20.99 ms host-196.202.236.220.mtn.cn (196.202.236.220)
11 22.43 ms host-154.76.126.102.mtn.cn (154.76.126.102)
12 131.79 ms 41.181.247.106
13 132.22 ms 41.181.244.166
14 143.66 ms lx-bundle-21.qcore2.ldn.london.as6453.net (195.219.17.174)
15 363.65 ms lf-bundle-19-2.qcore2.nto.newyork.as6453.net (64.86.143.82)
16 310.40 ms 63.243.218.8
17 ...
18 297.21 ms lf-ae-20-2.tcore2.svl-santaclara.as6453.net (66.198.101.132)
19 291.98 ms lf-ae-0-2.tcore1.svl-santaclara.as6453.net (63.243.251.1)
20 292.22 ms lf-ae-20-3.tcore1.00s-seattle.as6453.net (63.243.225.54)
21 ... 23
24 340.39 ms ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 307.58 seconds
root@dante-Latitude-E7450: /home/dante

```

2. Brute force the website <http://testphp.vulnweb.com/> and find the directories that are present in the website.

My task was successfully carried out and came out with some findings which will be seen on a screenshot and some explanation of the screenshot.

```

This XML file does not appear to have any style information associated with it. The document tree is shown below.
<?xml version="1.0"?>
<cross-domain-policy>
  <script id="HdxVideoBootstrapper"/>
  <script id="CitrixBcrApi"/>
  <allow-access-from domain="*" to-ports="*" secure="false"/>
</cross-domain-policy>

```

Finding:
I discovered a misconfigured crossdomain.xml file at [path you found], which contains:

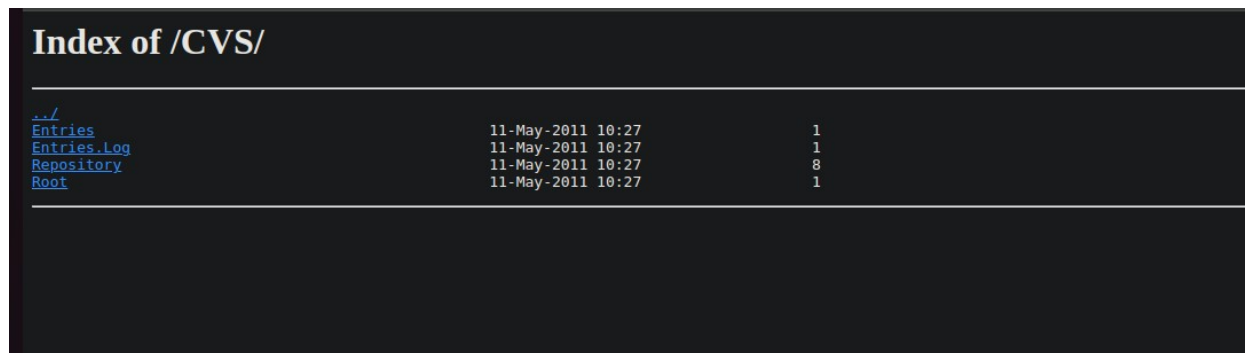
- Wildcard domain access (*)
- Access to all ports (*)
- Secure flag set to false

Implication:
This misconfiguration allows any external domain to access resources on the server via Flash or similar technologies, creating an avenue for cross-domain attacks and

potential data exfiltration.

Mitigation Recommendation:

- Limit <allow-access-from> to only trusted domains.
- Avoid wildcard domain and port usage.
- Set secure="true" to restrict to HTTPS connections.
- If Flash is not used, remove the file entirely.



Index of /CVS/		
./		
Entries	11-May-2011 10:27	1
Entries.log	11-May-2011 10:27	1
Repository	11-May-2011 10:27	8
Root	11-May-2011 10:27	1

The screenshot above shows an open CVS directory (/CVS/) with index browsing enabled. Here's what that means and why it's important:

What is CVS?

CVS stands for Concurrent Versions System. It's an old version control system used by developers to track changes in source code.

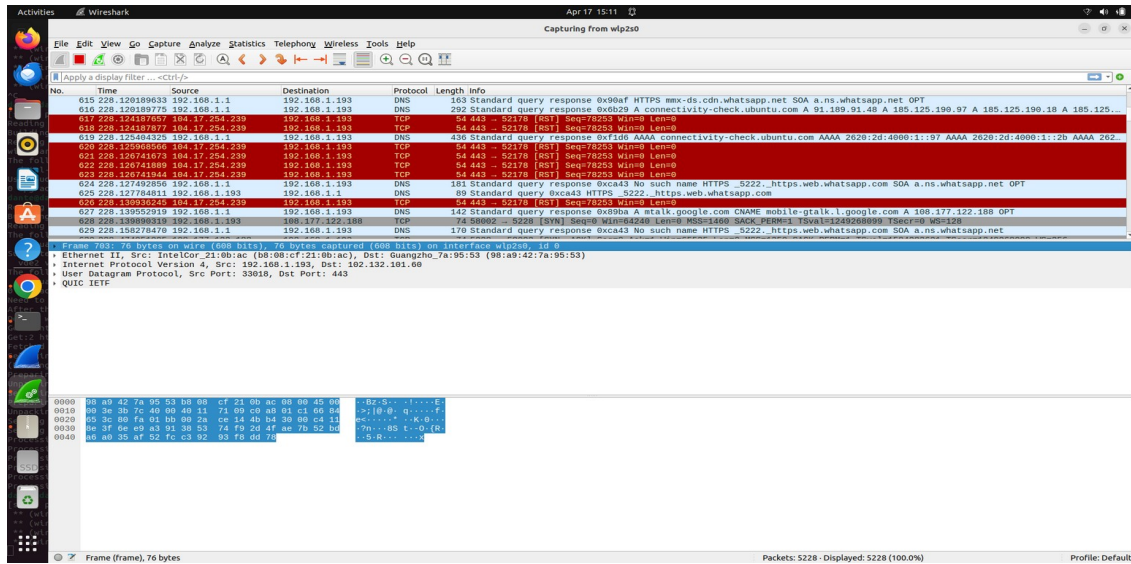
When you find a /CVS/ directory publicly accessible, it often contains internal development metadata that was accidentally uploaded to the web server.

Contents Explained:

- Entries: Lists files in the directory and their revision numbers.
- Entries.log: Contains a log of modifications made to files.
- Repository: Path to the repository – can reveal internal folder structure.
- Root: Path to the CVS repository server – may expose internal network or server info.

Security Implications:

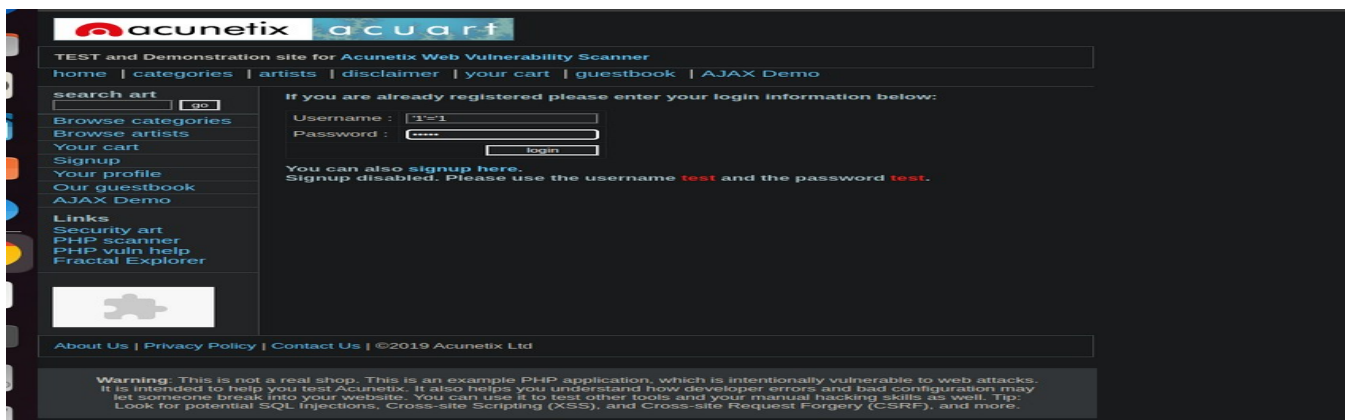
1. Information Disclosure:
 - Reveals internal structure of the web application or repository.
 - May leak filenames, paths, or even sensitive business logic files.
2. Reconnaissance for Attackers:
 - Attackers can identify file names or versions of components to target.
 - Can lead to exploitation of old or vulnerable files not directly linked in the UI.
3. Potential Code Leakage:



Both user
name and
passwords
have been

transmitted through this protocol.

4. Perform SQL injection on the login or search page of <http://testphp.vulnweb.com/> and check if the website is vulnerable to SQLi by extracting database information. I was able to lounge a syntax where I discovered the following errors and what they mean.



You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '1'='1' AND pass='admin'" at line 1

- This shows that the SQL query you're trying to inject is malformed.
 - The snippet `'1'='1' AND pass='admin'` was likely inserted into a vulnerable SQL input field.
 - The error suggests that your injected string **broke the original query**.
-

Why I am Seeing This Error

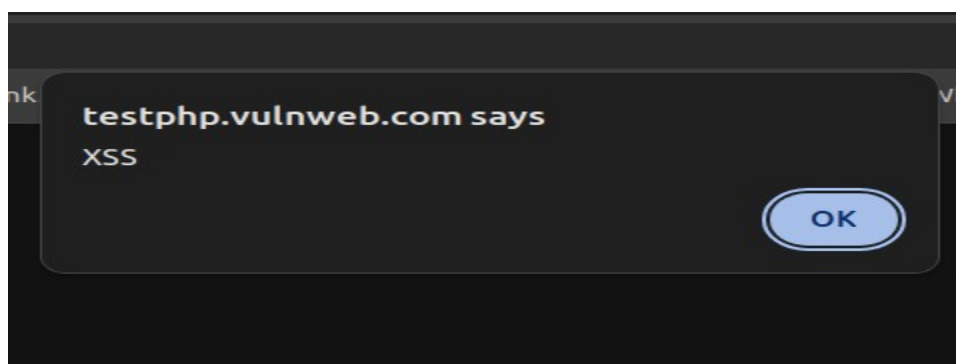
This usually happens when:

1. The query you're injecting into isn't being terminated correctly (e.g., missing `'` or `"`).
2. You're injecting into a field but not correctly balancing quotes or SQL syntax.
3. The application **isn't vulnerable** or is doing some form of input sanitization.

Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '1'='1' AND pass='admin" at line 1

5. Inject malicious JavaScript payloads in input fields (such as the comment section or search box) to see if the website is vulnerable to stored or reflected XSS attacks.

I was able to inject this malicious javascript code `<script>alert('XSS')</script>` to the website which gave me the result which will be seen on the screenshot



The screenshot is a pop-up alert box from the website testphp.vulnweb.com saying "XSS". This implies that the site has a Cross-Site Scripting (XSS) vulnerability. XSS is a vulnerability that allows an attacker to inject dangerous scripts into web pages visited by other users. In this case, the alert box is one common way of demonstrating that any JavaScript code can be executed in the browser and hence demonstrating the presence of the vulnerability.

Security Impacts

Attackers can leverage XSS vulnerabilities to steal cookies, session tokens, or other sensitive information, impersonate users, deface websites, or lead users to malicious sites.

This vulnerability compromises user data as well as the integrity of the vulnerable web application.

Recommendations

To avert and contain XSS vulnerabilities, the following are recommended:

Input Validation and Sanitization: Always validate and sanitize user input on both client-side and server-side. Strip or encode special characters that may be interpreted as code.

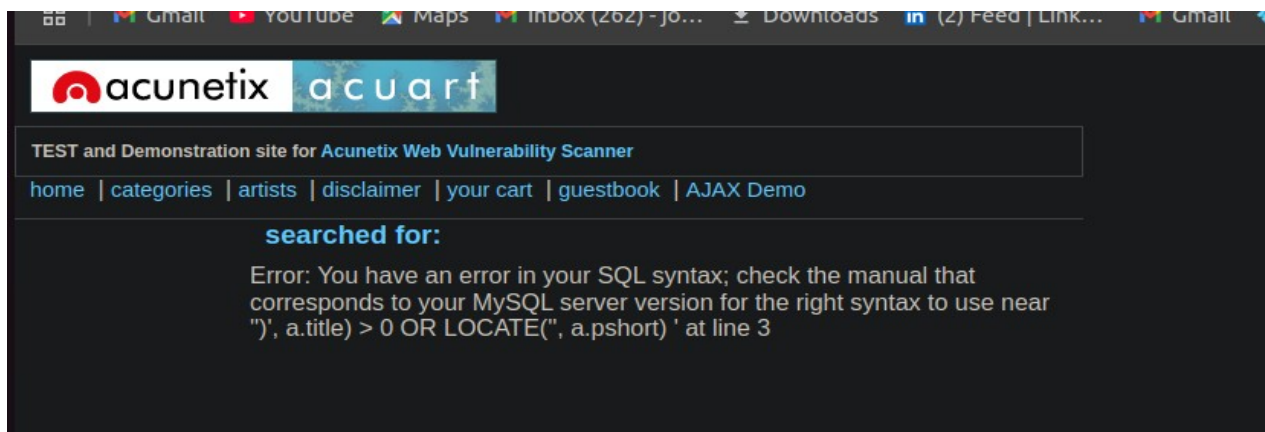
Output Encoding: Encode data before sending it to the browser, especially in HTML, JavaScript, and CSS environments.

Use Security Libraries/Frameworks: Use libraries or frameworks that have built-in defense against XSS.

Content Security Policy (CSP): Implement a strong Content Security Policy to restrict the sources upon which scripts can be executed.

Periodic Security Testing: Regularly scan web applications for XSS and other issues with automated scanners and manual testing.

By implementing these recommendations, XSS attacks can be significantly reduced, protecting both the website and its users from harm.



The following is a web application error message (Acunetix test site) of a SQL syntax error:

The error message:

"Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near."

This is the message shown when the application tries to execute a malformed SQL query. The error is reported to the user, revealing details about the database schema and query. This typically occurs when user input is inserted into a SQL query without validation or sanitization.

This is a common indicator of SQL Injection vulnerability. The attacker might have provided a specially crafted input to interfere with the SQL query such that the application displays this error. These vulnerabilities can assist attackers in tampering with database queries, hijacking sensitive data, or even destroying the entire database.

Recommendations

To correct and prevent SQL Injection vulnerabilities:

Use Prepared Statements/Parameterized Queries: Insert user input directly into SQL statements and always employ prepared statements or parameterized queries. This does not enable attackers to modify the query structure.

Input Validation and Sanitization: Sanitize and validate all user input for accepting only the expected data format and type.

Error Handling: Do not show detailed database error messages to users. Display generic error messages and on the server side, log detailed errors to use for debugging.

Least Privilege Principle: Ensure the database user account used by the application has the least privileges necessary.

Regular Security Testing: Perform regular security testing, both automated and manual, to detect and remediate SQL injection vulnerabilities.

TASK (CTF)

1) IR Playbooks

- Incident Response Phases: Identification, containment, recovery, and lessons learned.
- IR Tools: Log analysis, network forensics, and endpoint monitoring.
-

Playbook Creation: Build customized incident response playbook.

Bellow, I was able to respond to the following questions which will be seen with a screen shot of the question s and answers.

Task 1 Introduction

Knowing what actions to take in case a specific alert is triggered can often become confusing when dealing with alerts in a [SOC](#). Incident Response playbooks help reduce some of the confusion arising from such scenarios. But what are [IR](#) playbooks, and how do one create them? Let's learn in this room.

Objectives

In this room, we will be able to answer the following questions:

- What are [IR](#) playbooks, and how are they used?
- How do we capture the different steps of the [IR](#) process in a playbook?
- What roles and responsibilities are assigned to the different members of the [SOC](#) in a playbook?

Prerequisites

Before starting this room, please ensure that you have completed the following:

- [Intro to IR and IM](#) room
- [Incident Response](#) Module
- [Advanced ELK Queries](#) room

Answer the questions below

I have completed the prerequisites for this room.

No answer needed

Correct Answer

As organisations mature, they also try to document the scenarios people are expected to encounter in their daily work routines and the steps they should take when those scenarios arise. In most organisations with a mature SOC, processes govern everything, defining the roles and responsibilities of different people. In a SOC, since the primary routine is monitoring alerts, these processes primarily govern how to respond to different alerts.

The Incident Response Process

The Incident Response process is the primary governing process for responding to incidents. Although this process differs from one organisation to another in semantics, most functional parts of the process remain similar. This process defines different metrics that govern how incidents are responded to. Mainly, an incident response process will include the following:

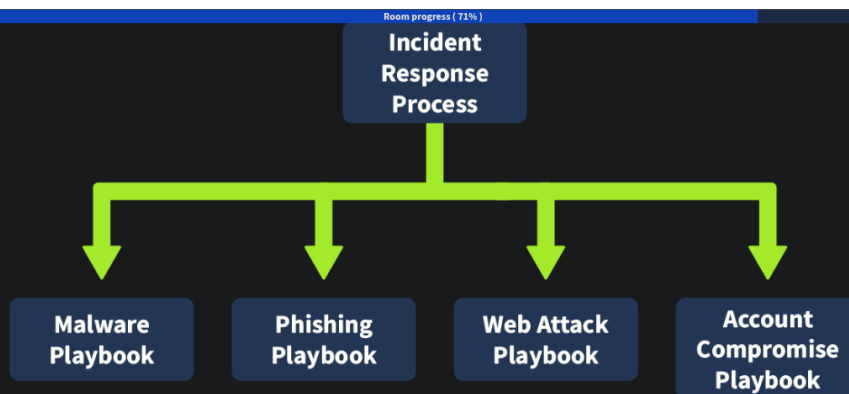
- A RACI matrix that defines the roles and responsibilities of different people.
- An escalation matrix that defines how and when incidents are communicated up the escalation ladder to the management.
- A severity matrix that defines the criteria for assigning severity to an incident.
- The procedures for handling crises from a cyber security standpoint.

In essence, it ensures that when an incident happens, the organisation is prepared to handle it, and people don't have to think on their feet about what to do next. Although sometimes crises might dictate deviating from the written process, it helps to have the confidence that one knows what to do when an incident occurs.

The Need for Playbooks

Since organisations already have an incident response process, why are playbooks required? The difference is mainly in the granularity of the response process. The IR process defines the high-level steps needed during an incident. It superficially mentions the stages of the IR process and does not dig into details about what steps must be taken during each stage. For example, the IR process might mention that containment and eradication actions will be taken at a particular stage without going into details about containment and eradication.

Incident Response Process

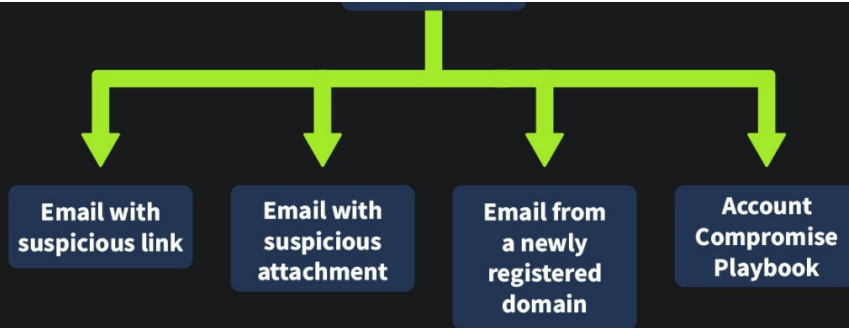


In a crisis, differences of opinion might arise regarding what steps to take to contain and eradicate a threat. While some might prefer searching on one portal for threat intelligence related to a particular artefact, others might have more confidence in another portal, and others might believe it's unnecessary to search on any portal altogether.

To avoid such conflicts, processes that define in such granularity what steps might be taken for each type of incident are needed. We can call these processes IR playbooks. In short, playbooks are processes that define in detail what granular steps need to be taken for each different type of alert that we receive. So, there should be a different playbook for each type of incident: phishing, malware, account compromise, policy violation, ransomware, or other types of incidents.

Use Cases and Playbooks

When monitoring is set up in a SOC, one major part is building use cases. Since most organisations produce terabytes of logs daily, it is impossible to properly view and analyse them manually. So, use cases are built to flag suspicious activity that needs further investigation. Once the use case is triggered, the analyst analyses the logs which triggered the use case and decides what actions must be taken. These actions are written in the playbooks. Therefore, we can reasonably assume that every use case created by the detection engineering team needs to have a playbook assigned to it. However, while the detection engineering team might develop hundreds of use cases, only a dozen playbooks are created for them. While there is a unique playbook for every use case, multiple use cases might trigger a single playbook, making it a one-to-many mapping.



Automating Playbooks

So far, we have identified that playbooks contain repeatable steps to follow whenever a use case triggers an alert. Depending on the organisational dynamics, some of these steps might be automated. The first step in automating something is often to divide it into small, repeatable steps, which the playbooks already do. Therefore, a SOC team might use a SOAR platform to automate partial or complete playbooks, relieving a lot of pressure from the analysts and making their lives easier. However, this process often takes time, and not everything can be automated. So, different organisations are at varying levels of automation at any given time, depending on their resources and goals. Nevertheless, having well-defined playbooks helps organisations take the next step towards automation and reducing alert fatigue from the analysts.

Creating playbooks, use cases, and an IR plan makes it very simple for the analysts to understand what to do in any scenario. They have documents to help them perform their jobs effectively, which means that the SOC's output is consistent, and there is little room for ambiguity. Playbooks also help the SOC teams identify opportunities to automate repetitive tasks and make their jobs easier. In the coming tasks, we will discuss the playbooks in a way that helps us follow them and equip us to create them when the need arises.

Answer the questions below

Can multiple use cases trigger a single playbook? y/n

y

✓ Correct Answer

Naturally, playbooks are designed to follow the steps of the IR process. Therefore, most organisations divide playbooks by the different steps of the IR process. Preparation is the first step, so let's start with that.

Preparation

Most organisations don't include this stage of the IR process in their playbooks. Since preparation is the stage of IR before the detection or identification of an incident, and a playbook is triggered after an incident is detected, it makes sense that this part is not present in most organisation's playbooks. However, this does not mean that no preparation needs to be done regarding playbook development. This phase is usually covered in the prerequisites part of the playbook.

Prerequisites of Playbooks

Like the IR process, the prerequisites of playbooks are created to ensure that the capability of detecting, investigating, and responding to an incident is available. Without this capability, the playbook might never trigger. As described previously, each playbook refers to a few use cases that will be the starting point of the playbook. Therefore, triggering use cases also need to be noted in the prerequisites of the playbook. In short, the following points should be ensured before a playbook is created, and these prerequisites can be indicated at the start of the playbook.

- All relevant logs are present and integrated into the SIEM.
- The logs are appropriately parsed, and the required fields are extracted and searchable.
- The logs contain all the required fields, such as machine information, IP information, process name, and more.
- Use cases are created on the specific behaviour that needs to be flagged and responded to.
- The recommended security controls are applied, representing the organisation's policies.

Prerequisites for Phishing Playbook

Now, let's use the above-mentioned general prerequisites to create more specific prerequisites for an example phishing playbook.



Relevant Logs	• EDR logs • Sysmon logs • Syslog • Windows event logs • Network communication logs
Required Fields	• Process names • Parent process names • Process ID • File/Process hashes • Process image path • Command line parameters • Activity details
Possible Use Cases	• Suspicious parent-child relationship • Suspicious file access • Suspicious registry events • Suspicious network activity
Recommended Security Controls	• Malware quarantine in EDR • Shellcode blocking • Exploit prevention

As with the phishing playbook, these sample prerequisites can be changed based on the organisation's requirements, and they might add general security guidelines based on their policies.

Answer the questions below

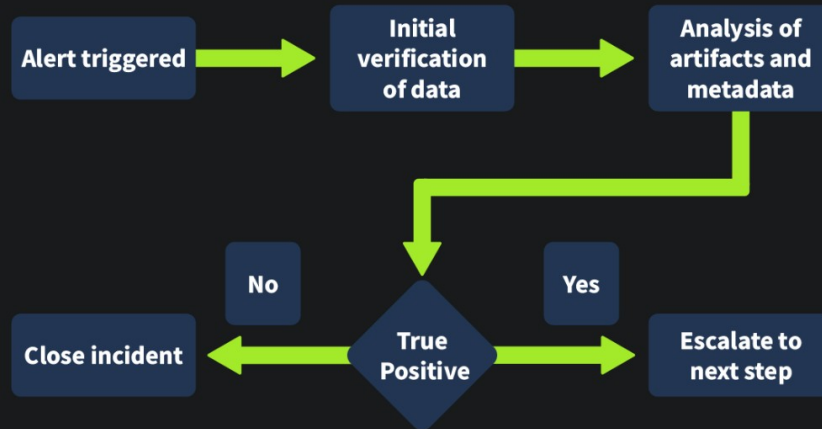
What stage of the IR process can be translated into prerequisites for the playbooks?

✓ Correct Answer

The prerequisites explained what our use cases require to trigger an incident. Once the incident is triggered, the detection and analysis part of the IR process will start. From here on, playbooks contain detailed information on granular steps to perform for verification of the incident.

Workflow Diagrams

Playbooks often contain workflow diagrams that help users understand the process. This workflow diagram can be the first step when creating a playbook, which can be explained and expanded to add more details. An example workflow diagram of this stage of the IR process will look like the following illustration.



We can add further details in this diagram as per the detailed steps of the playbook, making a separate workflow diagram for each playbook.

Detection and Analysis Checklist

injection, and more. However, for this room, we will keep it generic. Some use cases that might trigger the malware playbook are as follows:

- EDR marked a process as malicious
- Suspicious file executing from temp directory
- Browser executing a suspicious script engine such as `PowerShell` or CMD

Although we can have separate playbooks for some types of malware, for the sake of this room, we will consider a single malware playbook that covers all these cases.

Analysis

Once any of the above-mentioned use cases get triggered, the analyst will perform the following steps to verify the alert:

- Identify the process that triggered the alert.
- To identify the binary's reputation, check the process's hash on VirusTotal, Hybrid Analysis, or similar platforms.
- On VirusTotal, check if the process is marked as safe, distributed by a known vendor, or if it is signed by that vendor. **Important Note:** Do not upload the binary to VirusTotal or any other third-party platform without consulting your management.
- If the process is clean but was used to execute a file (such as an MS Word file, PDF file, or `PowerShell` script), analyse the executed file using VirusTotal, Hybrid Analysis, or other similar platforms.
- Check the parent process of the process that triggered the alert. Using the above steps, see if the parent process is clean or malicious.
- Identify how the process/file landed on the affected system. Check network or proxy logs to identify suspicious downloads or email logs to identify if the file was delivered through a phishing email.
- If a phishing email was involved, trigger the phishing playbook.
- Execute the malware in a private sandbox (if available) to understand its behaviour.
- Note the malware's activities in a document, which will be used for later containment actions.
- Preserve evidence of malicious activity, like taking memory, disk, or triage images, without turning off the affected systems (if required).
- Perform forensic analysis of the collected forensic data to identify further IOCs.
- Perform an organisation-wide threat hunt to identify all affected machines.

Based on the above steps, the analyst can either close the incident if it is a False Positive or escalate it to the next level if it is a True Positive.

Answer the questions below

What steps should we follow if the incident is a False Positive?

✓ Correct Answer

Task 5 IR Process and Playbooks: Containment, Eradication, and Recovery

The analyst will decide whether to close or escalate the incident based on the analysis results in the previous phase. If the incident is closed as a False Positive, the analyst might send the use case for fine-tuning to avoid such False Positives. If it is a True Positive, it might just be an authorised or expected activity, which the analyst will verify from the initiator of the activity, or it will be a True Positive that needs remediation. At this point, the incident will need to be escalated.

Escalation Process

In most organisations, the L1 analyst will work on the identification and analysis part of the IR process, also called triage. If the incident is a False Positive, it will be closed. However, it will be escalated to the L2 analyst if it is a True Positive. The L2 analyst will take it through the containment, eradication, and recovery part, taking help from the L3 analyst where required, mainly including forensics analysis, malware analysis, or other advanced analysis. The L3 or the incident responder will also create and maintain the playbooks, updating them as required. Most organisations follow the process defined above. However, each organisation might make a few changes to the process to suit their needs.

Checklist for Containment, Eradication, and Recovery

The IR process's containment, eradication, and recovery phase is only triggered when the incident is a True Positive. Therefore, the checklist here will focus mainly on limiting and reversing the impact of the incident. We can chalk out the following checklist for this phase of the IR process:

- Identify the root cause of the incident.
- Identify the impact and the affected assets.
- Contain the threat by isolating the affected assets and limiting connectivity.
- Perform actions to remove the impact of the threat from the affected assets.
- Bring the assets back to the last known good configuration.
- Resume services as usual for all the affected assets.

Example From Phishing Playbook

Let's use the above checklist to build the phishing playbook's containment, eradication, and recovery part.

Containment

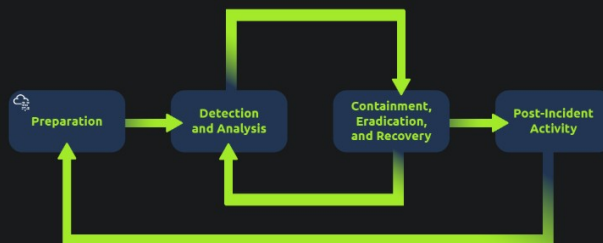
Once the analyst has identified the phishing email is a True Positive, they must take steps to contain the threat. These steps need to be spelt out in the playbook to avoid ambiguity. The following steps can be taken using the above checklist to contain a phishing email.

- Extract artefacts from the phishing email, such as IP addresses, email addresses, file hashes, domains, etc.
- Block the sender's email address, domain, and IP address on the email gateway.



At question 5, I was unable to complete this task due to how complex it was

Task 6 IR Process and Playbooks: Post-Incident Activity



Post-incident activity is the last stage of the IR process. The steps to be taken at this stage vary from incident to incident and will depend on the gaps identified during the process. The following questions are addressed during post-incident activity.

- Why did the incident happen (or using the 5 Whys method, which help reach the root cause)?
- What gaps were identified, which, if plugged, would have helped avert the incident?
- How can we improve People, Processes, and Technology to avoid such incidents in the future?
- What steps, if taken, could have minimised the impact of the incident?

As might be evident, this activity will be highly subjective based on the organisational dynamics, the type of incident, the impact, and the gaps found during the incident investigation. Therefore, it isn't easy to outline specific steps in playbooks that might be taken as part of this stage of the IR process. Hence, this part is generally not added to the playbooks. Instead, the post-incident activity is guided by broad guidelines outlined in the IR plan instead of the playbooks.

It might also be noted that the scope and guidelines of post-incident activity might differ based on the incident severity, impact on the organisation, and organisation from the IR process. It is common for most organisations to perform post-incident activity only for high and critical-severity incidents. For these reasons, it is generally only added to the high-level IR plan and not in the playbooks. If required for an incident, the playbook can refer to the IR plan for initiating post-incident activity once an incident has been recovered.

Answer the questions below

What is the last stage of the IR process?

Post-incident activity

✓ Correct Answer

Task 7

Putting It Into Practice

Now that we have a pretty good idea of how playbooks work and how we might even be able to create them, let's put them into practice. We have logs from a machine infected by malware in the attached VM. Let's see if we can use the guidelines we laid out for the malware playbook to answer the questions below.

Setting up and Connecting to the Machine

Start the virtual machine by clicking on the green **Start Machine** button below.

Let the VM load for around 3 minutes, as it will run in the background.

To access the dashboard, you can do it in one of the following ways:

1. Connect via OpenVPN (more info [here](#)), then type the machine's IP `http://MACHINE_IP` in your browser's address bar.
2. Follow the link `https://LAB_WEB_URL.p.thehacks.com/` using your browser.

You'll be presented with the Kibana login screen. Enter `elastic` for the username and `elastic` for the password.

Scenario

Deer Inc. is working on research that is of national importance. Therefore, they remain in close contact with the national CERT, which also has a sensor in its network. The sensor can identify network anomalies, which are then communicated to Deer Inc. They have received a communication from the national CERT regarding suspicious network activity detected in their network. The following are the details shared by the national CERT:

Date	Destination IP	Source IP	Source Port	Destination Port
2024-08-28	171.25.193.9	192.168.64.4	59230	80

We have an instance of `Elasticsearch` and `Kibana` in the attached VM, which will act as an `SIEM` solution in this investigation.

Answer the questions below

What is the name of the process that initiated this communication?

Is this process malicious, as per VirusTotal? y/n

What is the name of the parent process of this process?

This process's parent was launched by another process, which is a notorious ransomware. Which ransomware is that?

Which playbook should be followed to respond to this incident?

Is this incident an FP (False Positive) or a TP (True Positive)?

In case the incident is a TP, what will be the next step in the IR process?

On this part, I was unable to complete some task due to how confusing they were.

And that's a wrap. In this room, we learned about playbooks, especially:

- What playbooks are, and what their place in the documentation and processes hierarchy of an organisation is.
- How the different stages of the IR process are mapped to action items in a playbook.
- How we can use a playbook to investigate an incident.

Let us know what you think about this room on our [Discord channel](#) or [Twitter account](#). See you around

Answer the questions below

Yay! Now I can create IR playbooks.

Learning Outcomes

- **Technical Proficiency:** I gained practical experience in various cybersecurity tools and techniques, including vulnerability scanning, penetration testing, and cryptographic analysis.
- **Understanding of Cybersecurity Lifecycle:** I developed a comprehensive understanding of the steps involved in securing systems, from initial vulnerability assessment to implementing mitigations.
- **Problem-Solving Skills:** Tackling complex security challenges enhanced my analytical thinking and my ability to devise effective solutions under pressure.
- **Professional Development:** My experience improved my ability to work in a team, communicate technical information clearly, and manage time efficiently in a fast-paced environment.

Challenges and Solutions

- **Adapting to Complex Tools:** Initially, mastering advanced cybersecurity tools like Metasploit and Wireshark was challenging. I overcame this by dedicating time to study tutorials and practicing in a simulated environment, which significantly improved my proficiency.
- **Handling Advanced Security Scenarios:** The complexity of real-world security threats required a deep understanding of underlying principles. I tackled this by engaging in continuous learning and seeking guidance from my coordinator and team members.

Conclusion

My internship at Hack Secure was an enriching experience that significantly expanded my

knowledge and skills in cybersecurity. The practical exposure to real-world security challenges and the application of advanced tools have solidified my interest in pursuing a career in cybersecurity. This experience has been instrumental in preparing me for the complexities of the cybersecurity field.

Acknowledgments

I express my sincere gratitude to Hack Secure, especially my mentor, Mr. Aman Pandey, and assistant mentor Mr. Prabhat Raj, for their guidance and support throughout my internship. I also thank Amrita Vishwa Vidyapeetham for providing this internship opportunity, which has been crucial in my personal and professional development.

This report encapsulates the essence of my internship experience, highlighting the integration of academic knowledge with practical skills in a professional setting. It reflects my journey of learning, growth, and development in the field of cybersecurity.